

Practical Task (L3T08): Server Security

Vulnerability: Unsafe Content-Security-Policy (CSP) Header

- Target: <https://www.gov.uk>
- Tool used: Pentest-Tools Website Vulnerability Scanner (Light Scan)
https://pentest-tools.com/website-vulnerability-scanning/website-scanner/scans/G5Ulca9SLkPe31gz?view_report=true
- Risk Level: Low
- Classification: CWE-1021 | OWASP Top 10 2025 – A02: Security Misconfiguration

Description:

The scan identified that the website's Content-Security-Policy (CSP) HTTP response header contains unsafe directives. The following issues were detected:

- The **frame-ancestors** directive is not explicitly set to **none**, which explains that the site could potentially be embedded in an iframe on another domain, leaving it open to clickjacking attacks.
- The **report-uri** directive is deprecated in CSP Level 3 and should be replaced with **report-to**.
- The **script-src** directive includes **self**, which can be problematic if the server hosts JSONP limits Angular applications or user-uploaded files, as these could be used to execute malicious scripts.

Risk:

- An attacker could exploit a weak CSP to execute arbitrary JavaScript in the context of the vulnerable application, potentially stealing session tokens, redirecting users and performing actions on their behalf.

Solutions:

- Remove unsafe values from CSP directives
- Set **frame-ancestors: none** or **self** to prevent clickjacking.
- Replace the deprecated **report-uri** directive with **report-to**.
- Use cryptographic nonces or hashes instead of **self** for inline script allowances.
- Explicitly whitelist only trusted sources for scripts, styles and other resources.

References

OWASP CSP Cheat Sheet:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

MDN Web Docs – CSP: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>